

AwaazLabs UVA — Priority list (distributable)

Source of truth: docs/AwaazLabs UVA Audit.md (audited main @ 94e7000, 2026-09-13). Voice/latency context (not a finding list): docs/CTO_CONTEXT_LLM_LATENCY_AND_CARTESIA_HUMANIZATION.md.

How to read this file: The top is the working brief (who does what, which folders, Wave 1 roster). **Every item's full detail is below** in the catalog — Owner, Wave, Where, Why, and a link to the audit write-up. Search an ID (e.g. F-H12) instead of scrolling. Wave 1 people: read the intro + merge rules + your Wave 1 table; open the catalog only for those IDs.

Audit severity is unchanged (Critical → High → Medium → Low in the catalog below). **Execution order is Wave, not Critical → Low.** This deadline is performance and a working browser deliverable.

Deliverable bar (Wave 1): a host can npm install @awaazlabs-uva/voice (and @awaazlabs-uva/agents for the host backend), complete a **browser** call, and get snappy first audio with humanized TTS. PSTN, recording consent, SSO, legal, and most security wait.

Owners: - **Habiba** — voice loop (worker pipeline, turn latency, humanization, SDK connect/refresh). - **Ehsan** — production path (npm install/publish, CI green, control-plane mint/dispatch). - **later** — legal / owner-fill / commercial pack; not a coding wave.

Waves: - **1** — this deadline. - **2** — prod hardening after Wave 1 PRs are on main. - **parked** — SSO, billing, DPA, residency, admin UI, telephony-as-product.

This list contains every \$9 finding (**7 Critical · 18 High · 30 Medium · 15 Low**), Absent / Gate / owner-fill items, and the \$3-\$8 / \$0 narrative gaps that \$9 did not promote (catalogued with Owner + Wave). Wave 1 also lists delivery gaps the audit put in \$3 / \$6 / the CTO brief **without an F-* ID** — they are not invented findings.

The catalog is still grouped Critical → Low so an ID matches audit \$9. **Do not work in that order.** Wave 1 is first-deliverable ready (browser npm call + first audio), not “close Criticals then Highs.” The audit’s Conditional GO (close all seven Criticals before a pilot) is Wave 2 / parked, not this deadline.

Where / Why in the catalog are from the audit. This is **not** an implementation plan.

Merge rules (branches habiba and ehsan → PRs to main)

One owner per file in Wave 1. Do not open overlapping PRs on the same path. If a Wave 2 item needs a file the other person froze, wait until their Wave 1 PR is merged.

Habiba exclusive (Wave 1): sdk/src/, worker/latency.py, worker/providers/, worker/prompt_compact.py, worker/prompt_dump.py (only if needed for TTFT/token work), worker/tools.py, worker/telephony_tts.py, worker/main.py (**frozen for Ehsan until Wave 2**).

Ehsan exclusive (Wave 1): sdk/README.md, sdk/package.json, sdk-server/, .github/, examples/ (restore or delete the CI job and every dead link), README.md, docs/CLIENT_QUICKSTART.md, **all of control_plane/**, Makefile / pytest.ini only if required to keep CI green.

Neither touches in Wave 1: tenant_portal_api/, admin/, dashboard/, docker/, supabase/migrations/, telephony/.

F-H1 exception: do not un-whitelist 269 tests in Wave 1. If Habiba adds a test file, Ehsan may add **that one name** to pytest.ini — not the whole override. tests/test_prompt_compact.py already exists and is excluded; if Wave 1 compact/TTFT work needs it, whitelist **that file only**.

Wave 1 — this deadline (only work until the browser npm call works)

Habiba — voice works

Item	Why Wave 1	Files
F-H12, F-M14, F-M16, F-L7, F-L8	SDK call dies on one refresh blip, hangs with no timeout, collapses all 429s, throws under Next SSR, or drops later listeners	sdk/src/index.ts
F-H9	Hang-up / escalate stalls live audio	worker/tools.py
F-M2 (worker side only)	Unbounded persona → Groq ITPM / mid-call silence. Portal write-time cap is Ehsan Wave 2	worker/prompt_compact.py, prompt assembly in worker/main.py
Humanization + TTFT (not F-* ; CTO brief)	Cartesia emotion markup vs token tax; Gemini first-token too slow vs Groq; no history window; 429 retries = dead air	worker/main.py, worker/telephony_tts.py, worker/providers/llm/
Worker cold start (not F-* ; \$3.2)	Time-to-first-greeting after room join (VAD / session start)	worker/main.py

Parked for Habiba Wave 2+: F-C7, F-C4 (needs worker/main.py after Wave 1 freeze lifts), F-H10, F-M15 (full honesty API), F-L6, F-L10, F-M24, F-M25, F-H18 worker path, F-L15, F-M1 worker handlers, live prompt-injection test.

Ehsan — package installs and first mint is fast

Item	Why Wave 1	Files
F-H2	Red CI blocks merging to main; published SDK README has dead links	.github/workflows/ci.yml, sdk/README.md, README.md, docs/CLIENT_QUICKSTART.md; restore examples/ or delete the job and every reference
F-L1, F-L2	Same README.md as F-H2 — fix in that PR, do not come back later	README.md:60-63, :45-46
F-M21 (voice + agents only), F-L14	Integrator cannot trust the release path; release-sdk.yml if: is in the same file	sdk/package.json, .github/workflows/release-sdk.yml. Telephony package publish is Wave 2
F-M23 (sdk + sdk-server only)	Published metadata points at a personal repo	sdk/package.json, sdk-server/package.json. telephony/package.json is Wave 2
\$2 item 26	Server SDK @awaazlabs-uva/agents has no test	sdk-server/

	script	
Per-session LiveKit dispatch handshake (not F-* ; \$3.1)	New LiveKitAPI + TLS per session on the path to first audio	control_plane/app.py only <code>_run_dispatch_background (~:419-445)</code> . No drive-by CORS / dev-mint edits
Groq + Cartesia accounts live (not F-* ; \$6 Q1)	Audit already records Cartesia in a payment-failure state; Wave 1 TTS/TTFT is Cartesia + Groq	No code. Confirm Render/env keys and billing with whoever holds the accounts

Parked for Ehsan Wave 2+: F-C1, F-C2, F-C3, F-H1 (full whitelist removal), F-H3, Docker, telephony, secrets, legal, rest of \$6 inventory.

Delivery items that are not \$9 IDs

These were narrative in the audit / CTO brief and were previously omitted or buried. They are Wave 1 because they block the browser deliverable. **No F-* invented.**

Humanization + LLM time-to-first-token

- **Owner:** Habiba
- **Wave:** 1
- **Where:** `worker/main.py` (platform / Cartesia speaking rules, prompt assembly); `worker/telephony_tts.py`; `worker/providers/llm/` (Gemini vs Groq first-token path, 429 retry behaviour); conversation history sent every turn (no sliding window — CTO \$4.7)
- **Why it matters:** Measured Gemini TTFT dominates English voice delay; Groq is usable but free-tier ITPM plus humanization markup is a fixed token tax every turn. Full session history is also sent every turn (not in F-M2, which is persona length only). LiveKit/session-layer retries on Groq 429s become multi-second dead air — the demo-breaking failure mode. Latency and humanization are coupled through tokens-per-turn, not only model choice.
- **Full write-up:** `docs/CTO_CONTEXT_LLM_LATENCY_AND_CARTESIA_HUMANIZATION.md` \$§2-4, 10; audit \$3.2 (unbounded prompt / no runtime LLM budget)

Worker cold start / time-to-first-greeting

- **Owner:** Habiba
- **Wave:** 1
- **Where:** `worker/main.py` (session start, VAD preload)
- **Why it matters:** Setup latency after the room exists (plugin/VAD load, session build) is time-to-first-greeting, distinct from per-turn stop→audio.
- **Full write-up:** audit \$3.2; CTO brief \$6 (mint/provision/cold worker)

Control-plane per-session LiveKit dispatch handshake

- **Owner:** Ehsan
- **Wave:** 1
- **Where:** `control_plane/app.py:419-445` (`_run_dispatch_background`)
- **Why it matters:** Every session pays a fresh TLS handshake and event-loop construction on the critical path to first audio (`asyncio.run` + new LiveKitAPI client per dispatch). Concrete contributor to “>20s to first audio.”
- **Full write-up:** audit \$3.1. Touch **only** this function in Wave 1.

Groq + Cartesia accounts must be live for the demo

- **Owner:** Ehsan (with whoever holds billing — \$6 is owner-fill)
- **Wave:** 1
- **Where:** Render / provider dashboards; `GROQ_API_KEY`, `CARTESIA_API_KEY` (and LiveKit). Not a code change.
- **Why it matters:** Audit \$6 Q1 already records three provider accounts in a payment-failure state, **Cartesia partially**. Wave 1 humanized TTS is Cartesia; English TTFT is Groq. If either account is dead, the browser deliverable cannot be shown. Fish Audio / Soniox / the rest of the UNKNOWN inventory stay Wave 2.
- **Full write-up:** audit \$6 question 1

Catalog — every audit item, tagged Owner + Wave

This is the detail layer. IDs in the Wave 1 tables above are fully written up here (and so is Wave 2 / parked). Bands below are **audit severity**, not execution order. Do Wave 1 from the roster above first.

P0 — Critical

F-C1 — Hardcoded fallback JWT secret authenticates the entire telephony API

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `tenant_portal_api/telephony_routes.py:59-61`
- **Why it matters:** If `TENANT_PORTAL_JWT_SECRET` is not present as a real process environment variable on the portal service, every `/portal/telephony/*` route verifies tenant identity against `"mock_jwt_secret_for_tests"`. Anyone can mint `{"sub": "<any tenant uuid>", "aud": "tenant-portal", "iss": "uva-tenant-portal"}` signed with that string and then connect or rotate Telnix credentials, search and purchase phone numbers, configure routing, place outbound PSTN calls, and read all call records — for any tenant. The variable is absent from `.env.example` and from `docs/62-GUIDE-PROD-ENV-VARS.md` (which documents `ADMIN_JWT_SECRET` but not this one). Even when set only in `.env.local`, `tenant_portal_api/app.py:53-70` finds it and `telephony_routes.py` does not — legitimately issued tokens are rejected and forged ones accepted.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-C1** (\$9)

F-C2 — Unauthenticated session-mint endpoint

- **Owner:** Ehsan
- **Wave:** 2

- **Where:** `control_plane/app.py:577-590`, `:466-531`, `:263-268`
- **Why it matters:** `POST /v1/session/dev-mint` takes only `agentId`, looks up the owning tenant (`:348-355`), signs the mint request with the server's own copy of the tenant secret (`:475-486`), and returns a live LiveKit token. `DevSessionBody.publishableKey` (`:265`) is accepted and discarded. It is called with `auto_reset_quota=True` (`:587`), so on hitting the concurrency cap it executes `_dev_reset_concurrency — update quota_state set concurrent_now = 0` (`:358-363`) — wiping the tenant's live concurrency count. Anyone who obtains or guesses an agent UUID can consume a tenant's provider spend indefinitely. `dashboard/src/app/test-studio/page.tsx:64` calls this route (What was checked / §7).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-C2** (§9)
- **File freeze:** `control_plane/app.py` is Ehsan Wave 1 for dispatch only — do not mix `dev-mint` into that PR.

F-C3 — Credentialed wildcard CORS on the control plane

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `control_plane/app.py:91-94`, `:117-123`
- **Why it matters:** `.env.example:31-32` documents that an empty `CP_ALLOWED_ORIGINS` “defaults to permissive (allow all) for dev” — but the same code runs in production, and nothing warns or fails if the variable is unset. Combined with F-C2, any website can mint sessions from a visitor's browser. Admin and portal use explicit allowlists with no wildcard.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-C3** (§9)
- **File freeze:** same as F-C2 — not in the Wave 1 dispatch PR.

F-C4 — Unconditional call recording with no consent, disclosure, retention, or erasure

- **Owner:** Habiba
- **Wave:** 2
- **Where:** `worker/main.py` (`session.start(..., record={"audio": True, "traces": False, "logs": False, "transcript": False})`), including the inline override that records even when LiveKit sends `enable_recording=false`; `worker/session_recording.py:1-198`; `worker/main.py:742-760`; `worker/session_opening.py` (greeting only — no disclosure text); `supabase/migrations/0011_session_transcript.sql`, `0014_telephony_data_governance_audit.sql`, `0027_session_call_recordings.sql`
- **Why it matters:** Every browser and PSTN call is recorded to `audio.ogg`, uploaded to Supabase Storage at `{tenant_id}/{room_name}.ogg` (`session_recording.py:70`), and a 7-day signed URL is persisted in plaintext to `sessions.recording_url` (`:89,126-134`) where the portal returns it. The verbatim transcript is stored in `sessions.transcript`. Caller phone numbers are stored in `escalations.contact_info`. None of this is ever deleted; there is no consent capture, spoken disclosure, per-tenant opt-out, PII redaction function, deletion audit trail, or erasure path. Migration `0014` added retention columns to telephony infrastructure tables (trunks, SIP connections) and to none of the tables that hold personal data. §8 Part B maps the same gap to GDPR erasure and to CCPA/CPRA access and deletion.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-C4** (§9; also §8 Part A/B)
- **File freeze:** wait until Habiba Wave 1 `worker/main.py` PRs merge. Schema columns in `supabase/migrations/` are Ehsan in the same wave, sequenced after.

F-C5 — Dashboard ships Next.js with 1 CRITICAL and 7 HIGH vulnerabilities

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `dashboard/package-lock.json` → `next@14.2.35`; `dashboard/package.json:8` (`"next": "^14.2.0"`)
- **Why it matters:** 19 advisories on `next@14.2.35` alone, including GHSA-p293-qw3h-jr36 — unauthenticated remote code execution on Windows-hosted servers (CRITICAL) — plus 7 HIGH (two SSRF, four denial-of-service classes). `postcss@8.4.31` adds four more, two HIGH (arbitrary file read via attacker-controlled `sourceMappingURL`). This is the surface that holds tenant session tokens and reveals tenant signing secrets.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-C5** (§9; scan detail in Appendix A.2)

F-C6 — Tenant signing secret stored in plaintext and retrievable into the browser

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `supabase/migrations/0009_tenant_secrets.sql:4`; `control_plane/secrets_db.py:52`; `tenant_portal_api/app.py:405-412`; `tenant_portal_api/queries.py:248-261`; `dashboard/src/lib/portalAuth.ts:24`; `dashboard/src/app/credentials/page.tsx:58`
- **Why it matters:** (1) The raw HMAC secret is stored unencrypted in `tenants.hmac_secret` — while `0001_schema.sql:27`, `control_plane/secrets.py:3-5` and `docs/21-PHASE-1-SUPABASE.md:12` still assert “hash ONLY, never the secret.” The vestigial `hmac_secret_hash` is selected by the mint (`control_plane/mint.py:70,77`) and never used. (2) `GET /portal/credentials/secret` returns it to any holder of an 8-hour portal JWT. (3) That JWT lives in `localStorage`. (4) There is no self-service rotation — only an admin route (`admin/app.py:206`). One XSS yields the permanent signing credential. §8 Part A also marks `README.md:99` (“Zero client secrets”) **false as a system claim** — true of `@awaazlabs-uva/voice`, untrue of the dashboard product. Fix that sentence with F-C6, not in the Wave 1 dead-link README PR (see F-L3 note).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-C6** (§9)

F-C7 — LLM-driven write tools have no confirmation gate and no ownership check

- **Owner:** Habiba
- **Wave:** 2
- **Where:** `worker/tools.py:284-381` (`book_appointment`, `reschedule_appointment`, `cancel_appointment`); `:193-230` (`_post_client_tool`)
- **Why it matters:** `cancel_appointment` identifies the booking by a `customer_phone` string the caller supplied and the LLM transcribed. Nothing verifies the caller owns that number. `reschedule_appointment` has the same shape. Both are irreversible against a tenant's real calendar. The prompt-injection residual previously reached only `escalate_to_human`; it now reaches three destructive writes. No idempotency key is sent. No `MAX_TOOL_CALLS` budget exists. LLM-produced arguments flow into `_post_client_tool` and `INSERT`s with only the Python type signature — no schema validation before dispatch (§5b item 1 / §2 item 11). The live injection test (`tests/test_injection_live.py`) was never executed (§0); that run is a separate Wave 2 ticket after F-H1 collects it.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-C7** (§9; also §5b)
- **File freeze:** `worker/tools.py` is Habiba Wave 1 for F-H9 only. Confirmation-gate work is a second PR after that merge.

P1 — High

F-H1 — 53 of 75 test files (269 test functions) never execute

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `pytest.ini:8` (`python_files` whitelist)
- **Why it matters:** `python_files` overrides pytest's default `test_*.py` discovery with an explicit 22-file list. The 53 excluded files contain 269 test functions, including the entire telephony suite (18 files, ~170 tests), `test_tools_webhook.py`, `test_session_recording.py`, `test_stale_jobs.py`, `test_interruption.py`, `test_injection_live.py`, `test_greeting_fields.py`, all four `test_latency_phase*.py` files, and every `test_phaseN*_remediation.py` file. Commit `2fb14a5` describes that telephony suite as complete; mechanically it has never been run by `make gate` or CI. Any new test file is also silently skipped unless `pytest.ini` is edited. The 158 tests that do run give a false coverage signal.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H1** (§9; collection evidence in Appendix A.4)
- **Wave 1 exception:** if Habiba adds a test file, add **that one** whitelist entry only. Do not restore default discovery until Wave 2. `tests/test_prompt_compact.py` is already on disk and excluded — whitelist it only if Wave 1 compact/TTFT work needs those two tests.

F-H2 — CI contains a job that cannot pass; 11 dead documentation links, including in a published npm README

- **Owner:** Ehsan
- **Wave:** 1
- **Where:** `.github/workflows/ci.yml:69-99`; `README.md:31,45,46,85,104`; `docs/CLIENT_QUICKSTART.md:10,11,40,69,134,135`; `sdk/README.md:22,23,129,130,165,166`
- **Why it matters:** `example-app-build` runs `npm ci` in `examples/web-client` and `examples/host-backend`, which do not exist (deleted in `df97bf6`, 2026-08-18). A permanently red pipeline trains people to ignore CI — which is how F-H3 becomes dangerous. `sdk/README.md` is the README published to npm, so every consumer of `@awaazlabs-uva/voice` gets six links to deleted files. The historic directories were `examples/basic-webclient` and `examples/host-backend-node` — the CI paths never matched even before deletion.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H2** (§9)

F-H3 — Production deploys are not gated on CI

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `.github/workflows/deploy-prod.yml:3-5`; `.github/workflows/deploy-staging.yml:3-5`
- **Why it matters:** Push to `main` fires Render deploy hooks with no `needs`: on CI and no `workflow_run` trigger. Combined with F-H2 (CI always red) and F-H1 (most tests never run), there is no automated barrier between a commit and production. `if: env.HOOK_URL != ''` means a missing or rotated hook secret produces a green build that deployed nothing. No approval step, no rollback job, and no portal deploy hook — the service that backs the dashboard and all telephony is deployed by an undocumented manual process.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H3** (§9)

F-H4 — Rate limits are keyed on unauthenticated input and checked before authentication

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `control_plane/app.py:544`, `:291-298`; `tenant_portal_api/machine_auth.py:201`, `:172-179`
- **Why it matters:** `_rate_limited(x_tenant_id)` runs on a raw `X-Tenant-Id` header before any signature verification. An attacker who knows a tenant UUID (displayed in the dashboard as the “publishable key”) can send 120 junk requests per minute and lock that tenant out of session minting, and 30/minute to lock them out of agent management. No credential is needed.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H4** (§9)

F-H5 — In-process, unbounded rate-limit and replay state

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `control_plane/app.py:253`; `tenant_portal_api/machine_auth.py:169`; `tenant_portal_api/telephony_webhooks.py:36-37`
- **Why it matters:** Four security structures live in process memory: the mint rate limiter, the machine rate limiter, and the webhook signature/event replay sets. All reset on every deploy or restart, none are shared across workers (N workers ⇒ N× the stated limit), and `_hits` / `_seen_webhook_signatures` / `_seen_webhook_event_ids` grow without bound.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H5** (§9)

F-H6 — Telnix webhook events are lost permanently on durable-write failure

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `tenant_portal_api/telephony_webhooks.py:357-359`, `:361-377`, `:280-305`
- **Why it matters:** `event_id` is added to an in-memory set before `_persist_telnix_webhook_event`. On write failure the handler logs a warning (`:371-374`) and still returns HTTP 200 (`:377`), so Telnix never retries; a retry would be rejected as a duplicate anyway. Unmatched events are never inserted (`:280-305`); `except Exception: pass` at `:307` hides insert failures. Call terminal status and quota release can be lost forever.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H6** (§9)

F-H7 — Token refresh bypasses tenant status, quota, and session state

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `control_plane/app.py:301-345`, `:593-605`
- **Why it matters:** Refresh verifies only the LiveKit JWT signature and re-issues the same grants. It never re-reads `tenants.status`, never re-checks quota, and never checks whether the session row has been closed. There is also no cap on the number of refreshes. A tenant suspended for non-payment or abuse keeps every in-flight call alive. The admin suspend control is not a stop control.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H7** (§9)
- **Note:** Client retry of a failed refresh is Habiba Wave 1 (F-H12). This item is the control-plane re-check, not the SDK timer.

F-H8 — No SSRF protection on tenant-supplied tool gateway URLs, despite the docstring

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `tenant_portal_api/tools_webhook.py:1, :19-48`; consumed at `worker/tools.py:201-220`
- **Why it matters:** The module docstring claims “SSRF-aware”. The function checks scheme, embedded credentials, and query strings — and performs no host validation. Cloud metadata, loopback, private ranges, and `.internal` hostnames are accepted. The worker then POSTs from inside the platform network. `http://` is permitted, so `x-tool-gateway-secret` travels in cleartext. The five tests in `tests/test_tools_webhook.py` never run (F-H1).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H8** (§9)
- **File freeze:** Habiba Wave 1 `worker/tools.py` is F-H9 only — do not start SSRF there. Validator lives in Ehsan’s portal module.

F-H9 — Blocking database calls inside async coroutines stall live audio

- **Owner:** Habiba
- **Wave:** 1
- **Where:** `worker/tools.py:61, worker/tools.py:87`
- **Why it matters:** `end_conversation_summary` and `escalate_to_human` are `async def` and call synchronous `psycopg.connect(...)` directly. That blocks the event loop for a TCP+TLS handshake to Supabase during a live call — audio, VAD and TTS stop — at hang-up and escalation. Every other worker DB touch uses `asyncio.to_thread` (e.g. `worker/main.py:214, :463`).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H9** (§9)

F-H10 — Urdu has zero provider redundancy and the pipeline has no fallback

- **Owner:** Habiba
- **Wave:** 2
- **Where:** `worker/providers/capabilities.py:102-122`; `worker/providers/registry.py:45,57,86`; `worker/providers/llm/groq.py:70`; `worker/providers/tts/uplift.py:63`
- **Why it matters:** `ur` lists exactly one provider per layer: Gladia STT, Gemini LLM, Uplift TTS. The registry raises `UnsupportedProviderError` rather than substituting, there is no retry/failover/circuit breaker, and two adapters set `max_retry=0`. Any vendor outage or rate limit takes 100% of Urdu traffic offline. Gladia’s 429 ceiling is documented at roughly 5 concurrent sessions; Uplift’s ceiling is still unmeasured (`docs/42-RESEARCH-QUEUE.md` RQ-001).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H10** (§9)

F-H11 — No production migration path; the only runner destroys all data

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `scripts/db_reset.py:1-55`; `supabase/migrations/0001_schema.sql:6-11`
- **Why it matters:** No `schema_migrations` table and no forward-only runner. The only automation is DEV-ONLY `db_reset.py`, which applies `0001_schema.sql` — a file that opens with `drop table if exists usage_events, quota_state, sessions, agents, voices, tenants cascade`. Production schema changes are hand-applied with no record. A mistaken `make db-reset` against a production connection string destroys every tenant, agent, session and usage record. The docstring already records two development footguns (preview URLs wiped, admin account wiped on every reset).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H11** (§9)

F-H12 — A single failed token refresh terminates the call

- **Owner:** Habiba
- **Wave:** 1
- **Where:** `sdk/src/index.ts:411-441` (`scheduleTokenRefresh`)
- **Why it matters:** On refresh failure the SDK emits one `error` event and returns. The timer is not rescheduled. The LiveKit token expires ~60 seconds later and the call dies. One transient network blip ends the conversation; the host only sees generic `session_failed`. `scheduleTokenRefresh` is called at `:235` (connect) and `:437` (successful refresh) and nowhere else.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H12** (§9)

F-H13 — Service JWT signing keys are auto-generated into a file at import time

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `admin/app.py:46-68`; `tenant_portal_api/app.py:53-70`
- **Why it matters:** When the env var is absent, both services generate a random secret and append it to `.env.local` at import. In a container this either crashes (read-only filesystem) or silently rotates every deploy, invalidating every session. `docker/admin.Dockerfile:20-26` documents this failure; the code still does it. `docs/62-GUIDE-PROD-ENV-VARS.md` covers `ADMIN_JWT_SECRET` but not `TENANT_PORTAL_JWT_SECRET` (see F-C1).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H13** (§9)

F-H14 — No brute-force protection, TOTP replay guard, or failed-login audit on either login endpoint

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `admin/app.py:114-126`; `tenant_portal_api/app.py:287-298`; `admin/security.py:440-456`
- **Why it matters:** Neither `/admin/login` nor `/portal/login` is rate-limited, throttled, or locked out. `totp_verify` accepts the ± 1 -step window with no record of consumed codes, so a valid code is reusable for up to 90 seconds, contrary to RFC 6238 §5.2. `record_admin_action` is only called on success, so `admin_audit_log` contains no failed attempts. The admin portal has full cross-tenant read access and can rotate any tenant’s secret.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H14** (§9)

F-H15 — aiohttp==3.14.1 carries three advisories, one HIGH

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `requirements.txt:2`
- **Why it matters:** GHSA-cq5v-8q36-5273 (HIGH) — out-of-bounds heap read in the C HTTP response parser on a malformed chunked response; plus HTTP request smuggling via WebSocket upgrade (GHSA-mfx4-hv73-q22v) and an unnegotiated-compression issue (GHSA-mq44-7p77-q5h7). `aiohttp` is on the worker request path and, via the monolithic requirements file, on the tenant portal too. (Audit §9 garbles the HIGH id as GHSAcq5v-8q36-5273; Appendix A.1 has the correct id.)
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H15** (§9; OSV scan Appendix A.1)

F-H16 — No `.dockerignore`; the worker image copies the entire build context

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** absent `.dockerignore`; `docker/worker.Dockerfile:34` (`COPY . .`); `docker/tenant-portal-api.Dockerfile:7` (`COPY scripts/scripts/`)
- **Why it matters:** `COPY . .` with no ignore file places `.git/` (the complete 278-commit history), `tests/`, `scratch/`, `docs/`, and any local `.env.local` inside the runtime image. The portal image separately ships every provisioning and admin script into the runtime container.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H16** (§9)

F-H17 — Outbound PSTN calls ignore the monthly minutes cap and fail open on unknown tenants

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `tenant_portal_api/telephony_queries.py:308-338`; compare `control_plane/mint.py:121-130`
- **Why it matters:** `reserve_call_quota` reads only `tenants.max_concurrent`. It never touches `max_minutes_month` or `minutes_this_month`. A tenant blocked from browser sessions by the monthly cap can place unlimited outbound PSTN calls. `if not tenant_row: return True` (:314-315) grants quota to a tenant ID that does not exist — fail-open on the spend path. No rate limit on `POST /portal/telephony/outbound-calls` and no spend circuit breaker.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H17** (§9)

F-H18 — Billing and quota release happen only on clean shutdown

- **Owner:** Habiba (worker callback) / Ehsan (schedule `scripts/reconcile_sessions.py` and `scripts/reconcile_telephony.py` without touching `worker/main.py`)
- **Wave:** 2
- **Where:** `worker/main.py:730-835`, `:832-834`; `scripts/reconcile_sessions.py`; `scripts/reconcile_telephony.py`
- **Why it matters:** Session close, concurrency decrement, and `usage_events` writes happen only in LiveKit shutdown callbacks. Crash/OOM/eviction leaves the session open, the slot consumed, and the call unbilled. `tenant_portal_api/queries.py:264-276` documents that this already produced a tenant showing 13 “live” calls whose oldest was 96 hours old. Both reconcile scripts exist and nothing schedules either. The audit fix text is “schedule both reconcile scripts.” The callback body is wrapped in `except Exception` → `logger.warning` (:826-828).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-H18** (§9)
- **File freeze:** Habiba’s worker path waits for Wave 1 `worker/main.py` to merge. Ehsan may add a cron/workflow on **both** existing scripts in parallel (`reconcile_sessions.py` and `reconcile_telephony.py`).

P2 — Medium

F-M1 — 28 exception handlers swallow errors silently (14 in production service code)

- **Owner:** Ehsan (portal / control-plane handlers) / Habiba (worker handlers)
- **Wave:** 2
- **Where:** Full list in Appendix A.3; worst: `control_plane/app.py:204`, `tenant_portal_api/telephony_webhooks.py:307`, `tenant_portal_api/telephony_credentials.py:118`, `worker/session_recording.py:82`. Worker-side also: `worker/main.py:913,927,1069` (incl. VAD preload), `worker/latency.py:146,164,256,282`, `worker/tools.py:139`, `worker/providers/llm/gemini.py:57`.
- **Why it matters:** Guideline §2 names this pattern explicitly. A DB outage returns a fake voice catalogue; a failed credential re-encryption is invisible; a failed recording delete is invisible. `/v1/voices` is also unauthenticated (`control_plane/app.py:173-249`) — the swallow is F-M1; do not treat the public catalogue itself as a separate ticket.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-M1** (§9 / Appendix A.3)
- **Note:** `worker/session_recording.py:82` is Habiba Wave 2 with F-C4. Other worker handlers in A.3 are Habiba Wave 2 after `worker/main.py / latency.py / tools.py` Wave 1 freeze lifts. Ehsan owns the portal/control-plane handlers. Wave 1 cold-start may *read* the VAD-preload `except` at `main.py:1069`; do not treat log-hygiene as the Wave 1 goal.

F-M2 — `agents.prompt` has no length limit

- **Owner:** Habiba (Wave 1 worker compact) / Ehsan (Wave 2 write-time cap)
- **Wave:** 1 (worker) then 2 (portal + schema)
- **Where:** `tenant_portal_api/app.py:107`; `supabase/migrations/0001_schema.sql:40`
- **Why it matters:** Every LLM turn pays for the full persona. This is the mechanism behind the observed Groq ITPM exhaustion. `worker/prompt_compact.py` mitigates only for Groq, only at session build, after the tenant has already stored an arbitrarily large prompt.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-M2** (§9)
- **Split:** Habiba Wave 1 = `worker/prompt_compact.py` + assembly in `worker/main.py`. Conversation-history truncation and Groq 429 retry behaviour are the separate Wave 1 Humanization + TTFT item, not this ticket. Ehsan Wave 2 = server-side cap at `tenant_portal_api/app.py:107` (portal is frozen in Wave 1).

F-M3 — Unbounded `limit` query parameters

- **Owner:** Ehsan
- **Wave:** 2

- **Where:** `tenant_portal_api/app.py:416`; `tenant_portal_api/telephony_routes.py:551`; `tenant_portal_api/queries.py:279`
- **Why it matters:** `?limit=1000000` returns every session with full transcripts — memory pressure and a data-exfiltration amplifier.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-M3** (§9)

F-M4 — No body-size limit on the public Telnix webhook

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `tenant_portal_api/telephony_webhooks.py:339-341` (`await request.body()`)
- **Why it matters:** Unauthenticated endpoint reads an arbitrarily large body into memory before signature verification.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-M4** (§9)

F-M5 — Raw exception text returned to clients

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `tenant_portal_api/telephony_routes.py:541` (`f"Outbound call setup failed: {e}"`); `control_plane/app.py:148` (`f"failed: {e}"` in `/healthz/deep`)
- **Why it matters:** Leaks internal hostnames, driver messages, and stack context. `/healthz/deep` is unauthenticated.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-M5** (§9)

F-M6 — `/docs` and `/redoc` enabled unauthenticated in production

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `control_plane/app.py:112-113`
- **Why it matters:** Publishes the full API schema, including `dev-mint` (F-C2), to anyone.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-M6** (§9)

F-M7 — Hand-rolled cipher for telephony credentials while `cryptography` is already a dependency

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `tenant_portal_api/telephony_credentials.py:26-43`, `:125-151`
- **Why it matters:** HMAC-keystream + HMAC tag is unreviewed custom crypto in a codebase that already imports `cryptography==50.0.0` (used for Ed25519 at `telephony_webhooks.py:18`). `_master_key` is plain `sha256(env_value)` with no KDF or salt. `decrypt_provider_secret:87-88` silently returns ciphertext-as-plaintext in mock mode.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-M7** (§9)

F-M8 — `agents.tools_auth_secret` stored in plaintext

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `supabase/migrations/0026_agents_tools_webhook.sql:8`; read at `worker/config.py:110`
- **Why it matters:** A third secret-handling standard in one schema: tenant HMAC plaintext, telephony credentials custom-encrypted, tool secret plaintext.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-M8** (§9)

F-M9 — All Docker images run as root, use floating base tags, and define no healthcheck

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `docker/*.Dockerfile`
- **Why it matters:** No `USER` directive anywhere; `FROM python:3.12-slim` without a digest means builds are not reproducible and a compromised upstream tag is inherited silently. No `HEALTHCHECK`.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-M9** (§9)

F-M10 — No security headers on any service

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** All FastAPI apps; `dashboard/next.config.js`
- **Why it matters:** No CSP (the main mitigation for F-C6's XSS chain), no HSTS, no X-Frame-Options, no X-Content-Type-Options.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-M10** (§9)

F-M11 — `used_nonces` grows without bound

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `supabase/migrations/0004_nonces.sql`; written at `control_plane/mint.py:98-101`, `tenant_portal_api/machine_auth.py:234-237`
- **Why it matters:** One row per successful mint, forever. No purge job exists. The `used_at` index implies cleanup was planned and never written.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-M11** (§9)

F-M12 — `escalations` is write-only — no API, no UI, no query

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** written at `worker/tools.py:93-97`; grep for `escalations` across `tenant_portal_api/`, `admin/`, `dashboard/src/`, `sdk-server/src/` returns nothing
- **Why it matters:** A shipped, LLM-callable feature produces records that no one can read through the product. Caller phone numbers accumulate in a table with no reader and no retention.

- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M12** (§9)
- **File freeze:** read API is portal/dashboard (Ehsan). Do not add it inside Habiba Wave 1 worker/tools.py.

F-M13 — No deletion path for agents or tenants

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** No DELETE route in tenant_portal_api/app.py or admin/app.py
- **Why it matters:** Agents accumulate permanently; tenant offboarding is impossible, which also blocks GDPR erasure (F-C4).
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M13** (§9)

F-M14 — Browser SDK fetch calls have no timeout

- **Owner:** Habiba
- **Wave:** 1
- **Where:** sdk/src/index.ts:121, :181, :415
- **Why it matters:** A hung host backend leaves connect() pending forever with no error and no hook — the client-side shape of the “>20s silence” symptom.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M14** (§9)

F-M15 — Silent provider and model substitution

- **Owner:** Habiba
- **Wave:** 2
- **Where:** worker/providers/llm/groq.py:42-51; worker/telephony_tts.py via worker/main.py:236,248
- **Why it matters:** Eight advertised Groq model IDs collapse to one live model; telephony silently swaps both TTS and LLM. The capabilities API keeps advertising the tenant’s choice. A sub-processor disclosure that names the wrong vendor is a compliance problem (§8 Part B sub-processor transparency).
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M15** (§9; also §8 Part B)
- **Note:** Wave 1 humanization/TTFT may use the Groq/Cartesia path; do not spend Wave 1 on a full honesty API.

F-M16 — Only three SDK error codes; all 429s collapse to one

- **Owner:** Habiba
- **Wave:** 1
- **Where:** sdk/src/index.ts:46, :189-190
- **Why it matters:** A host cannot distinguish plan cap from rate limit from upstream provider 429 — so it cannot back off correctly or tell the user anything useful.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M16** (§9)

F-M17 — Missing index on usage_events.session_id

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** supabase/migrations/0001_schema.sql:76, 0010_tenant_portal_indexes.sql; join at tenant_portal_api/queries.py:61-67
- **Why it matters:** /portal/agents joins on an unindexed column for every tenant on the most-visited page. Degrades as usage_events grows.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M17** (§9)

F-M18 — Test-only authentication backdoors in production telephony code

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** tenant_portal_api/telephony_routes.py:73-74, :145-150
- **Why it matters:** TELEPHONY_ALLOW MOCK PORTAL AUTH=1 returns a hardcoded tenant with no token; TELEPHONY_ALLOW MOCK MACHINE AUTH=1 accepts the literal "valid_mock_signature". Default off and documented as dev-only, but they live in the module that spends money, and nothing asserts at startup that they are off.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M18** (§9)

F-M19 — Mock-mode switches disable webhook signature verification and credential decryption

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** tenant_portal_api/telephony_webhooks.py:121; tenant_portal_api/telephony_credentials.py:52,59,87
- **Why it matters:** TELEPHONY_PROVIDER_MODE correctly defaults to "real" (tenant_portal_api/telephony_config.py:14), so this is not live today. A single env typo (test, local) silently turns off Telnix signature checking and credential encryption at once, with no startup warning.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M19** (§9)

F-M20 — No dependency audit, secret scan, bundle check, or SBOM in CI

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** .github/workflows/ci.yml (four jobs, none of these); Makefile:8,15 (gitleaks / bundle-check only in make gate)
- **Why it matters:** F-C5 / F-H15 would have been caught automatically. The repo already has gitleaks and bundle-check commands — they are not wired into CI.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M20** (§9)
- **File freeze:** Wave 1 ci.yml is F-H2 (delete/fix example-app-build) only. pip-audit needs Python ≥3.12 (numpy==2.5.1); the audit used OSV.dev because the local interpreter was 3.10.

F-M21 — npm publishing has no provenance, no changelog, and covers only one of three packages

- **Owner:** Ehsan

- **Wave:** 1 (voice + agents) / 2 (@awaazlabs-uva/telephony)
- **Where:** .github/workflows/release-sdk.yml:11-41 ; no CHANGELOG* in any package; all three at version: 0.1.0 while the handover documents 1.0.1
- **Why it matters:** No provenance attestation, no changelogs, and @awaazlabs-uva/agents and @awaazlabs-uva/telephony have no release path. \$2 item 27 notes the telephony SDK is not published by CI (voice only).
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M21** (\$9)

F-M22 — make secrets silently depends on an uninstalled tool

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** Makefile:15
- **Why it matters:** gitLeaks missing locally means make gate cannot pass on that machine. The gate correctly fails rather than passing vacuously — but it means nobody is running it.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M22** (\$9)

F-M23 — npm package metadata points at a personal repository

- **Owner:** Ehsan
- **Wave:** 1 (sdk/ , sdk-server/) / 2 (telephony/)
- **Where:** sdk/package.json:6-8 ; sdk-server/package.json ; telephony/package.json ; README.md:4
- **Why it matters:** Published packages point at github.com/habiba-imran/urdu-agent-SDK while origin is Finova-Solutions/urdu-voice-agent-SDK . Supply-chain and bus-factor risk: who can push to that repo?
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M23** (\$9; also \$4 Bus factor)
- **Note:** telephony/ is frozen in Wave 1. README.md:4 can be the same Ehsan Wave 1 README PR as F-H2.

F-M24 — Full prompts and transcripts written to logs and to a file on disk by default

- **Owner:** Habiba
- **Wave:** 2
- **Where:** worker/main.py:602,608 ; worker/prompt_dump.py ; .env.example:44 (UVA_DUMP_PROMPTS=1 documented as default on)
- **Why it matters:** Caller PII reaches application logs and docs/last_session_prompt.txt — neither covered by any retention or redaction rule (F-C4).
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M24** (\$9)
- **File freeze:** after Wave 1 worker/main.py merge. Wave 1 may read prompt_dump while shrinking tokens; do not treat log-PII as the Wave 1 goal.

F-M25 — No worker health or readiness endpoint

- **Owner:** Habiba
- **Wave:** 2
- **Where:** worker/main.py (LiveKit agent process exposes no HTTP surface)
- **Why it matters:** Control plane has /healthz , /healthz/deep , /healthz/warm ; the process that serves audio has nothing. A wedged worker is undetectable except by a failing call.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M25** (\$9)

F-M26 — No cap on agents per tenant

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** tenant_portal_api/app.py:308
- **Why it matters:** Unbounded resource creation on an authenticated but unmetered endpoint.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M26** (\$9)

F-M27 — Duplicate migration version and two incompatible naming schemes

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** 0014_telephony_data_governance_audit.sql / 0014_telephony_idempotency_webhook_tenant_scope.sql ; timestamped 20260801185628_...
- **Why it matters:** Ordering happens to resolve alphabetically today; the numbering discipline is broken and a third contributor will break it. Compounds F-H11.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M27** (\$9)

F-M28 — No CODEOWNERS , no PR template; branch protection unverifiable

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** .github/ contains only workflows/ and ISSUE_TEMPLATE/
- **Why it matters:** Combined with F-H3 (push to main deploys), lack of an enforced review requirement would mean a single unreviewed commit reaches production. Confirm branch protection in \$6 Q5.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M28** (\$9)

F-M29 — DbSecretProvider caches secrets for 60 s, delaying rotation

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** control_plane/secrets_db.py:35 , :99-128 ; except Exception: pass at :118-119
- **Why it matters:** A rotated secret keeps working for up to a minute after rotation, and a DB outage silently reverts authentication to a stale env-based map.

- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M29** (§9)

F-M30 — Monolithic requirements.txt shipped to the tenant portal image

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** docker/tenant-portal-api.Dockerfile:6
- **Why it matters:** Installs livekit-agents, numpy, openai, python-socketio into a service that imports none of them — larger image, larger attack surface, and it inherits the vulnerable aiohttp (F-H15). Control-plane and admin images correctly use slim files.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-M30** (§9)

P3 — Low

§9 Low table has ID / FINDING / WHERE only (no Why column). Why below is taken from the cited supporting section.

F-L1 — README’s “Run Database Migrations” step runs scripts/reconcile_sessions.py --dry-run, which applies no migrations

- **Owner:** Ehsan
- **Wave:** 1
- **Where:** README.md:60-63
- **Why it matters:** Operators following the README believe they applied migrations; they did not (§4 documentation table).
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-L1** (§9)
- **Note:** Same README.md PR as F-H2.

F-L2 — README links to two files that do not exist (VAAS_GODTIER_MASTER_PLAN_V2.md, VAAS_COLLABORATION_GUIDE.md)

- **Owner:** Ehsan
- **Wave:** 1
- **Where:** README.md:45-46
- **Why it matters:** Onboarding docs point at nothing (§4 documentation table). Overlaps F-H2’s README.md:45,46 line list; §9 still lists this as its own finding.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-L2** (§9)

F-L3 — “Enterprise-grade” and “Enterprise Production Infrastructure” claims outrun the product — no SSO, no RBAC, no audit export, no data residency, no DPA

- **Owner:** Ehsan
- **Wave:** parked
- **Where:** README.md:2,6
- **Why it matters:** Marketing claims that §2 items 32/36 and §8 Part B show are absent. Until Gate 6, remove the wording and do not sell enterprise tiers or telephony (§11).
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-L3** (§9)
- **Note:** Ehsan Wave 1 README PR should stay on dead links / F-L1. Do not expand that PR into marketing rewrite unless it is a one-line fix with zero extra files.

F-L4 — “publishable key” is literally the tenant UUID, not a separate credential, and is never validated server-side

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** tenant_portal_api/queries.py:238; admin/queries.py:262; control_plane/app.py:265
- **Why it matters:** Displayed as a distinct credential but is neither publishable-key-shaped nor separately revocable (§7). Also the unauthenticated rate-limit key in F-H4.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-L4** (§9)

F-L5 — Dashboard route gating is client-side only (mitigated — the backend enforces auth on every route)

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** dashboard/src/components/AppShell.tsx:41-56
- **Why it matters:** UI gate is cosmetic; rated Low because backend JWT enforcement was verified in §5a (§7).
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-L5** (§9)

F-L6 — Per-turn internal latency and stage breakdown are broadcast into the room, where the end user’s browser receives them

- **Owner:** Habiba
- **Wave:** 2
- **Where:** worker/latency.py:496-528,625-633; sdk/src/index.ts:345-348
- **Why it matters:** Internal stage timings leak to end users. §2 item 15 cites worker/latency.py:496-528,680-698 and sdk/src/index.ts:466-473; §7 notes the SDK emits them and the dashboard does not render them. **§9 WHERE is canonical**; the §2/§7 line numbers differ inside the audit itself.
- **Full write-up:** docs/AwaazLabs UVA Audit.md → **F-L6** (§9)
- **File freeze:** sdk/src/index.ts Wave 1 is F-H12 / F-M14 / F-M16 / F-L7 / F-L8 only.

F-L7 — SDK attaches audio elements to document.body with no SSR guard — throws if imported at module scope in Next.js

- **Owner:** Habiba
- **Wave:** 1
- **Where:** `sdk/src/index.ts:366`
- **Why it matters:** The project's own dashboard is Next.js; a module-scope import throws during SSR (§3.4).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-L7** (§9)

F-L8 — A throwing event listener silently prevents later listeners from firing

- **Owner:** Habiba
- **Wave:** 1
- **Where:** `sdk/src/index.ts:274-278`
- **Why it matters:** `emit` iterates listeners without try/catch; one throwing listener silently prevents all later listeners from receiving the event (§3.4).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-L8** (§9)

F-L9 — Dead code: `mint.py` selects `hmac_secret_hash` and never uses it

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `control_plane/mint.py:70,77`
- **Why it matters:** Comparison is against the raw secret; the unused select implies a verification step that does not happen (§3.1). Tied to F-C6's leftover hash column.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-L9** (§9)

F-L10 — `_cartesia_agent_session_extra` is a pure alias kept only for old test imports

- **Owner:** Habiba
- **Wave:** 2
- **Where:** `worker/main.py:433-437`
- **Why it matters:** Dead alias with no current callers except old tests (§9 title).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-L10** (§9)

F-L11 — Generated artefacts committed to the repo root (`graphify-out/` with two dated snapshots, `scratch/` with 5 files)

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** repo root
- **Why it matters:** Generated snapshots and scratch files inflate the tree (§3.7).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-L11** (§9)

F-L12 — `docs/63-GUIDE-WORKER-DEPLOYMENT-DEFERRAL.md` still states there is no worker Dockerfile

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `docs/63-GUIDE-WORKER-DEPLOYMENT-DEFERRAL.md`, contradicted by `docker/worker.Dockerfile`
- **Why it matters:** Deployment guide states a security/ops property the code no longer has (§4 documentation table).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-L12** (§9)

F-L13 — Stale `pythonpath = . pipecat_stubs` referencing a directory that never existed in this checkout (documented as such)

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `pytest.ini:5`
- **Why it matters:** Stale path in the same file whose whitelist already hides most tests (F-H1).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-L13** (§9)

F-L14 — `release-sdk.yml` uses `if: ${ secrets.NPM_TOKEN != '' }` where the sibling workflows use the documented `env: - mapping` workaround — verify against an actual run

- **Owner:** Ehsan
- **Wave:** 1
- **Where:** `.github/workflows/release-sdk.yml:34`
- **Why it matters:** GitHub does not list `secrets` among contexts available to a step-level `if`; inconsistency with sibling workflows is itself a smell (§4 CI/CD).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-L14** (§9)
- **Note:** Same file as F-M21 — fix in the Wave 1 release PR.

F-L15 — `_ensure_bucket` calls `list_buckets / create_bucket` on every single session end rather than once at startup

- **Owner:** Habiba
- **Wave:** 2
- **Where:** `worker/session_recording.py:33-41,65`
- **Why it matters:** Unnecessary Storage API calls on the recording path that already has no retention (F-C4).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → **F-L15** (§9)

Named in the audit, no finding ID

These are **not** extra inventions. The audit names them as Absent components, Gate remainder, §8 Part B obligations, or owner-fill, and §9 did not assign an **F-*** ID.

§2 Absent components (no **F-***)

§2 Absent rows that **already have** an **F-*** are not repeated here: **#30** examples → F-H2; **#33** production migration runner → F-H11.

Platform admin UI — Absent

- **Owner:** later
- **Wave:** parked
- **Where / evidence:** `admin/` is a JSON API only; no frontend in the repo. Operator console exists only as curl-able endpoints.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §2 item **29**

Billing / plans / payments — Absent

- **Owner:** later
- **Wave:** parked
- **Where / evidence:** No Stripe, no plans table, no invoice surface anywhere in the repo. Metering exists (`usage_events`); commerce does not. Payment-card data is N/A for that reason (§8 Part B).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §2 item **31**; also §11 Gate 6

SSO / RBAC / audit export — Absent

- **Owner:** later
- **Wave:** parked
- **Where / evidence:** One credential pair per tenant; no roles, no user table for tenants. Blocks any enterprise claim.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §2 item **32**; also named in **F-L3**

Observability stack (traces, metrics, alerts) — Absent

- **Owner:** Ehsan
- **Wave:** parked
- **Where / evidence:** Optional Sentry only (`control_plane/app.py:96-105`); no OTel, Prometheus, alerting. Latency hooks exist; an ops product does not.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §2 item **34**

Kill switch / rollback automation — Absent

- **Owner:** Ehsan
- **Wave:** 2
- **Where / evidence:** No such control in any workflow or service. §11 Gate 5 also asks for a rehearsed rollback (F-H3 already notes there is no rollback job).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §2 item **35**; also §11 Gate 5

Public legal / trust pack (ToS, Privacy, DPA) — Absent

- **Owner:** later
- **Wave:** parked
- **Where / evidence:** Not present in the repository. Blocks honest commercial sale. §8 Part B: signed data-processing terms with tenants — No.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §2 item **36**; also §8 Part B / §11 Gate 6

§2 Present, missing piece, no finding ID

§2 missing-piece rows that **already have** an **F-*** are not repeated (e.g. #3 → F-H7, #4 → F-C2, #25 → F-H12/F-M14, #27 unpublished telephony SDK → F-M21).

Live carrier proof still open

- **Owner:** Ehsan
- **Wave:** parked
- **Where / evidence:** Telephony (Telnyx + LiveKit SIP) is Present, but “live carrier proof still open per `state/PROGRESS.md`”.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §2 item **20**

Server SDK `@awaazlabs-uva/agents` has no test script

- **Owner:** Ehsan
- **Wave:** 1
- **Where / evidence:** `sdk-server/src/index.ts` (313 lines); §2 item 26 “No test script at all”.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §2 item **26**

§8 Part B / §11 Gate 3 — legal exposure not already an **F-***

Call-recording consent, disclosure, GDPR/CCPA erasure, and sub-processor transparency are already F-C4 / F-M13 / F-M15. Not repeated.

Obtain a legal opinion on biometric and two-party-consent questions

- **Owner:** later
- **Wave:** parked
- **Where / evidence:** Illinois BIPA / Texas CUBI — needs legal determination. Pipeline stores raw call audio indefinitely (`worker/session_recording.py`). Required before selling into IL/TX.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §8 Part B; §11 Gate 3

Secure sub-processor DPAs, including for the free-tier vendors

- **Owner:** later
- **Wave:** parked
- **Where / evidence:** No DPA references in the repository. Several vendors are on free tiers (`GROQ_API_KEY` free tier per `worker/providers/llm/groq.py:12-16` ; `UPLIFT_MODE` fixture/live), where a DPA typically does not exist. Customer call transcripts are transmitted to these vendors.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §8 Part B; §11 Gate 3

GDPR 72-hour breach notification / incident-response process — not handled

- **Owner:** later
- **Wave:** parked
- **Where / evidence:** No documented incident-response or notification process in the repository. There is no email or notification service, so there is also no mechanism to notify tenants.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §8 Part B (also §6 “Email / notification service — Does not exist”)

Data residency — not handled

- **Owner:** later
- **Wave:** parked
- **Where / evidence:** Single Supabase project, single region, single Storage bucket (`session-recordings`). No residency selection in schema or code. Also named in **F-L3**.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §8 Part B

§11 Gate 6 / §6 — commercial and ops claims not already an **F-***

A measured and published capacity sheet

- **Owner:** Habiba
- **Wave:** parked
- **Where / evidence:** §11 Gate 6; Uplift ceiling still unmeasured (RQ-001, cited under F-H10).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §11 Gate 6

A status page (and monitoring / on-call)

- **Owner:** Ehsan
- **Wave:** parked
- **Where / evidence:** §6 inventory row “Monitoring / on-call / status page — Does not exist.” Also §11 Gate 6.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §6; §11 Gate 6

Email / notification service — Absent

- **Owner:** later
- **Wave:** parked
- **Where / evidence:** §6 inventory: “Does not exist.” Required for tenant breach notification (§8 Part B).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §6; §8 Part B

Fill the §6 ownership inventory — every UNKNOWN cell is itself a finding

- **Owner:** Ehsan
- **Wave:** 2
- **Where / evidence:** Audit §0: “Every cell marked *UNKNOWN* — *owner must fill* is itself a finding.” Table covers GitHub org, Render, Supabase, LiveKit, Telnyx, Gemini, Gladia, Uplift, Deepgram, Groq, Cartesia, ElevenLabs, Fish Audio, Rime, Soniox, Sentry, npm, Domain/DNS. §6 Q1: if an account were suspended tomorrow, what breaks; three provider accounts are already in a payment-failure state (Fish Audio, Soniox, Cartesia partially). Wave 1 only needs Groq + Cartesia (+ LiveKit) confirmed live — that is the separate Wave 1 delivery item. This ticket is the rest of the table. Q4 (personal card/account) overlaps F-M23. Q5 (branch protection) is F-M28. Q6 (`TENANT_PORTAL_JWT_SECRET` on Render) is F-C1.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §0; §6

Production / staging / development secrets are not distinguished

- **Owner:** Ehsan
- **Wave:** 2
- **Where / evidence:** §6 Q2: `.env.example` describes one set of variable names for all environments and the repo has no mechanism to distinguish them.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §6 question 2

Database backups / restore have never been evidenced

- **Owner:** Ehsan
- **Wave:** 2
- **Where / evidence:** §6 Q3: “Has a database restore ever been tested? Nothing in the repository references backups at all.”
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §6 question 3

§3-§8 / §0 narrative gaps (no **F-*** ID)

These were previously omitted because §9 did not promote them. They are now tickets. **None are Wave 1** — they do not block the browser npm + first-audio deliverable. Empty `allowed_origins` actually helps a host-app demo (fail-open); tightening it is Wave 2.

Empty `allowed_origins` has no origin enforcement and no setter

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `control_plane/mint.py:118` ; default `'{}'` at `supabase/migrations/0001_schema.sql:30` ; §7: allowlist is displayed read-only, nothing can set it

- **Why it matters:** `if allowed_origins and origin not in allowed_origins` means an empty array skips the check. Every tenant is unrestricted until someone populates the column. There is no admin or portal route that sets it.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §3.1; also §7 “Origin allowlist management — No”
- **File freeze:** `control_plane/` Wave 1 is `_run_dispatch_background` only. Portal setter is Wave 2 (`tenant_portal_api/` is frozen in Wave 1).

Unbounded `_config_cache` in the worker

- **Owner:** Habiba
- **Wave:** 2
- **Where:** `worker/config.py:31`
- **Why it matters:** Module-level dict keyed by `(tenant_id, agent_id)` with no eviction. Grows for the life of the process.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §3.2
- **File freeze:** do not mix into Wave 1 `worker/main.py` / providers PRs. `worker/config.py` is Habiba Wave 2.

Browser SDK `@awaazlabs-uva/voice` has no test script

- **Owner:** Habiba
- **Wave:** 2
- **Where:** `sdk/package.json` (no `test` script); §3.4: the browser SDK that runs in every customer page has zero automated tests
- **Why it matters:** Server SDK is already §2 #26 (Ehsan Wave 1). The voice package is the customer-facing one and still has no tests beyond F-H12 / F-M14 / F-M16 behaviour work.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §3.4
- **File freeze:** Habiba Wave 1 is `sdk/src/index.ts` behaviour only. Ehsan wires `"test"` in `sdk/package.json` after her tests exist (same pattern as §2 #26).

No admin JWT revocation and no disable flag on `admin_users`

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `admin/` — 8-hour token remains valid after an account should be disabled; no disable flag on `admin_users`
- **Why it matters:** Stolen or departed-admin tokens cannot be killed except by rotating `ADMIN_JWT_SECRET` (which invalidates every session).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §3.5

No down migrations; `0013` indexes are not re-runnable

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** no down migrations anywhere; `0013_telephony_constraints_indexes_status_idempotency.sql:192-293` creates 28 indexes without `IF NOT EXISTS`
- **Why it matters:** Every migration is one-way (guideline §3 irreversible ops). `0013` is not re-runnable except because `db_reset.py` drops everything first. Compounds F-H11.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §3.6

RLS is decorative on the request path (ADR-005)

- **Owner:** Ehsan
- **Wave:** parked
- **Where:** `supabase/migrations/0002_rls.sql`; services connect as DB owner via `scripts/dbconn.py:30-50`; exception `worker/config.py:122-123`
- **Why it matters:** RLS policies protect nothing in the request path except that one worker read. Documented as intentional (ADR-005). Do not cite RLS as tenant-isolation evidence for other services. Not a Wave 2 rewrite.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §3.6

No installable package layout — `sys.path.insert` in 12 modules

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** 12 modules insert `sys.path` to reach `scripts/dbconn.py`; why `docker/tenant-portal-api.Dockerfile:7` must `COPY scripts/` (F-H16)
- **Why it matters:** Dependency graph is implicit. Portal image ships every provisioning script into the runtime container.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §4 Architecture

Telephony / worker god-files

- **Owner:** Ehsan (telephony) / Habiba (`worker/main.py` nested closures)
- **Wave:** parked
- **Where:** `telephony_service.py` (2,451 lines); `telephony_routes.py` (1,203 lines); `worker/main.py:708-905` nests a 200-line closure
- **Why it matters:** Hard to test in isolation; may be why the worker shutdown path has no unit test. Refactor is debt, not the deliverable or Wave 2 security.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §4 Code quality

Human-review confirmation does not exist for telephony or worker shutdown

- **Owner:** later
- **Wave:** parked
- **Where:** guideline §3 requires a written statement of which portions a human reviewed line-by-line
- **Why it matters:** Artefacts in the repo do not show that confirmation for the telephony subsystem or the worker shutdown path.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §4 AI-generated code, point 3

Large multi-concern commits

- **Owner:** later
- **Wave:** parked

- **Where:** e.g. `de77870`, `b5e88b1`; `examples/` deleted inside a TTS commit (`df97bf6`)
- **Why it matters:** Process debt. The `examples/` deletion is why F-H2's CI job is red. Fixing history is not a sprint; fixing the CI job is Ehsan Wave 1 (F-H2).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → \$4 CI/CD and git discipline

Control-plane ↔ admin and portal ↔ control-plane imports

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** `control_plane/app.py:51` imports `admin.audit.record_mint_rejection`; `tenant_portal_api/auth.py:22` and `telephony_routes.py:49-50` import `control_plane.secrets`
- **Why it matters:** Documented leaks. Control-plane image must vendor part of `admin/` (`docker/control-plane.Dockerfile:19`). Minor versus F-C1 / F-H16.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → \$4 Architecture

No per-call LLM budget or runtime spend circuit breaker

- **Owner:** Habiba
- **Wave:** 2
- **Where:** no `MAX_LLM_CALLS_PER_CALL`, no token ceiling per session, no spend guard; `scripts/usage_guard.py` is a `make usage-check` reporter, not runtime
- **Why it matters:** A runaway tool/LLM loop burns provider quota with no stop. Wave 1 humanization/TTFT reduces tokens-per-turn; it does not add a session circuit breaker.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → \$5b item 4

No record sufficient to reconstruct an LLM incident

- **Owner:** Habiba
- **Wave:** 2
- **Where:** `usage_events` records aggregate token counts per session (`worker/usage.py:61-89`) but neither provider nor model
- **Why it matters:** If a tenant disputes what the agent said or did, the only artefacts are the stored transcript and ephemeral logs.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → \$5b item 8

No rate limit on the public Telnix webhook

- **Owner:** Ehsan
- **Wave:** 2
- **Where:** Telnix webhook handler — \$5a “None at all on `/portal/login`, `/admin/login`, `/portal/telephony/outbound-calls`, or the Telnix webhook”
- **Why it matters:** Login throttling is F-H14; outbound-call rate limit is inside F-H17; body size is F-M4. The webhook itself is still unthrottled.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → \$5a Rate limiting
- **File freeze:** `tenant_portal_api/` is frozen in Wave 1.

No in-app first-run onboarding in the dashboard

- **Owner:** Ehsan
- **Wave:** parked
- **Where:** no in-app guidance anywhere in `dashboard/src/`
- **Why it matters:** Integrator onboarding for the npm SDK is README / quickstart (Ehsan Wave 1, F-H2). Dashboard first-run is a console UX gap, not the browser-SDK deliverable.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → \$7 Usability

Dashboard live UX pass (a11y, empty/loading/error, performance)

- **Owner:** later
- **Wave:** parked
- **Where:** colour-contrast, keyboard navigation, chart alt-text; whether every view uses `empty-state.tsx` / `skeleton.tsx` / `toast.tsx`; measured load times — marked *needs live review*; no running instance, no a11y or performance tooling
- **Why it matters:** \$0 and \$7 assessed the dashboard from source only. Radix primitives give an a11y baseline. Empty/loading/error components exist; the audit could not verify they are wired on every view. Not a code defect yet. Dashboard is frozen in Wave 1.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → \$7; also \$0 frontend method note / document-control “not covered”

Deeper Telnix provider-state reconciliation still unreviewed

- **Owner:** Ehsan
- **Wave:** parked
- **Where:** `tenant_portal_api/telephony_service.py` (2,451 lines) and `telnix_client.py` (1,083 lines) reviewed at interface/auth/quota/idempotency/error-handling level, not line-by-line
- **Why it matters:** Follow-up flagged in \$0. Live carrier proof is already \$2 #20 (parked). Not Wave 1 (PSTN out of scope).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → \$0 What was NOT audited

No live pentest, load, or soak test

- **Owner:** later
- **Wave:** parked
- **Where:** \$0 scope limitations; every exploit path is from reading code
- **Why it matters:** Items marked *needs live confirmation* require a controlled test. Not a coding ticket for this deadline.
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → \$0

Live prompt-injection test not executed

- **Owner:** Habiba
- **Wave:** 2
- **Where:** §0 / §5b; `tests/test_injection_live.py` (never collected — F-H1); F-C7 is the code fix this test is meant to verify
- **Why it matters:** Distinct from pentest/load/soak. The audit analysed the injection surface from code only and states which parts need a live test. F-C7's fix text is: run the live injection test and add it to a gate that actually runs. Do this after F-C7 and after F-H1 collects `*_live.py` under a `live` marker (deselect by default in CI).
- **Full write-up:** `docs/AwaazLabs UVA Audit.md` → §0; §5b; F-C7 fix
- **File freeze:** after Habiba Wave 1 `worker/tools.py` (F-H9) and Wave 2 F-C7.

Coverage vs the audit

§9 findings — 70/70 present, none extra

Band	IDs	Count
Critical	F-C1 ... F-C7	7
High	F-H1 ... F-H18	18
Medium	F-M1 ... F-M30	30
Low	F-L1 ... F-L15	15

No invented `F-*` IDs. No §9 finding omitted.

Wave 1 delivery items that are not `F-*`

Added for this deadline only (audit §3 / §6 / CTO brief; previously omitted or buried):

Item	Owner	Source
Humanization + LLM TTFT (incl. history window + Groq 429 dead air)	Habiba	CTO brief §§2-4, 10; §3.2
Worker cold start / first greeting	Habiba	§3.2; CTO brief §6
Control-plane <code>_run_dispatch_background</code> handshake	Ehsan	§3.1
Groq + Cartesia accounts live	Ehsan	§6 Q1 (Cartesia already payment-failing)

Unnumbered section — complete vs Absent / missing-piece-without-ID / §8 unique / §6 owner-fill / Gate remainder / §3-§8 narrative

Source	In this list	Already covered by an <code>F-*</code> (not duplicated)
§2 Absent #29, #31, #32, #34, #35, #36	yes	#30 → F-H2; #33 → F-H11
§2 Present, missing piece, no ID #20, #26	yes	other missing-piece rows already have IDs
§8 Part A “Zero client secrets” false as a system claim	yes (inside F-C6)	F-C6
§8 Part B unique (legal opinion, DPAs, 72h notice, residency)	yes	consent/disclosure/erasure/redaction/ <code>session_opening.py</code> → F-C4/F-M13; sub-processor transparency → F-M15; ToS/DPA pack → #36; CCPA deletion → same absence as GDPR / F-C4
§6 owner-fill (UNKNOWN cells, Q2, Q3, email, status page)	yes	Q1 Groq+Cartesia live check → Wave 1 delivery item; Q5 → F-M28; Q6 → F-C1
§11 Gate remainder	yes	see Gate mapping below
§3-§8 / §0 narrative (allowed_origins, <code>_config_cache</code> , browser SDK tests, admin JWT revoke, migrations/RLS, sys.path, god-files, LLM budget/incident log, webhook rate limit, onboarding, dashboard live UX, Telnix follow-up, no live pentest, live prompt-injection)	yes	<code>/v1/voices</code> swallow → F-M1; HMAC unused select → F-L9; blocking DB → F-H9; dispatch handshake → Wave 1 delivery item; schema validation of tool args → F-C7; <code>reconcile_telephony.py</code> → F-H18
Appendix A.3 worker silent handlers	yes (F-M1 split: Habiba worker / Ehsan portal)	F-M1

Gaps closed in this mapping pass (were in the audit, missing or incomplete on the list)

Audit source	What was wrong	Where it lives now
§0 / §5b / F-C7 fix	Live prompt-injection test listed separately from pentest; list only had pentest/load/soak	New unnumbered ticket, Habiba Wave 2
§7 empty/loading/error + §0 measured load times	Only a11y was ticketed	Expanded “Dashboard live UX pass”
F-H18 fix “both reconcile scripts”	Only <code>reconcile_sessions.py</code>	Also <code>scripts/reconcile_telephony.py</code>
CTO §4.7 history truncation; §4.4 Groq 429 dead air	Buried under humanization one-liner	Wave 1 Humanization + TTFT Where/Why
§6 Q1 Cartesia payment-failure	Buried in full inventory Wave 2	Wave 1 delivery item (Groq + Cartesia only)
§8 Part A README “Zero client secrets”	Not mentioned on F-C6	F-C6 Why
Appendix A.3 worker <code>except</code> list	F-M1 owned only by Ehsan	Split Habiba worker / Ehsan portal
F-C4 <code>session_opening.py</code> / <code>enable_recording=false</code> override	Disclosure path not named	F-C4 Where

\$5b item 1 no tool-arg schema validation	Inside F-C7 in the audit, omitted from catalog Why	F-C7 Why
---	--	----------

Reference notes (audit PDF wrapping vs canonical path)

ID	Audit §9 WHERE as printed	Canonical form used here
F-C1	docs/62GUIDE-PROD-ENV-VARS.md / 62-GUIDEPROD-ENV-VARS.md (line-wrap)	docs/62-GUIDE-PROD-ENV-VARS.md
F-H3	deploy-staging.yml:3-5	.github/workflows/deploy-staging.yml:3-5
F-H5 / F-H4 / F-M1 / F-M3 / F-M4 / F-M5 / F-M11 / F-M17 / F-M18 / F-M19	unprefixed machine_auth.py , telephony_*.py , queries.py , mint.py	tenant_portal_api/... or control_plane/mint.py
F-H15	GHSACq5v-8q36-5273 in §9 body	GHSA-cq5v-8q36-5273 from Appendix A.1
F-H16	docker/tenant-portalapi.Dockerfile:7 (line-wrap)	docker/tenant-portal-api.Dockerfile:7
F-C4	0011 , 0027	0011_session_transcript.sql , 0027_session_call_recordings.sql
F-M8	0026:8	supabase/migrations/0026_agents_tools_webhook.sql:8
F-M11	0004	supabase/migrations/0004_nonces.sql
F-M17	0010	0010_tenant_portal_indexes.sql
F-M21	release-sdk.yml:11-41	.github/workflows/release-sdk.yml:11-41
F-L6	§9: latency.py:496-528,625-633 + sdk ...:345-348 ; §2 item 15: :680-698 + sdk ...:466-473	Keep §9 WHERE; note the audit-internal mismatch
F-L12	docs/63	docs/63-GUIDE-WORKER-DEPLOYMENT-DEFERRAL.md

Not listed (clean / non-work, or already an F-* / Wave 1 item)

Do **not** add these as extra tickets:

- SQL injection / command injection: audit found none on the request path (§5a)
- Secrets in git history: clean scan (§0 / §5a)
- /v1/voices silent fallback: F-M1
- Unused hmac_secret_hash select: F-L9
- Blocking psycpg.connect in async tools: F-H9
- _run_dispatch_background handshake: Wave 1 delivery item (Ehsan)
- Worker cold start / humanization+TTFT / history window / Groq 429 dead air: Wave 1 delivery items (Habiba)
- Groq + Cartesia account liveness: Wave 1 delivery item (Ehsan)
- Running-env UNKNOWN cells (except Groq/Cartesia Wave 1 check): already “Fill the §6 ownership inventory”
- README “Zero client secrets”: F-C6
- Tool-arg schema validation / MAX_TOOL_CALLS: F-C7
- Recording disclosure / session_opening.py / PII redaction / deletion audit trail: F-C4
- reconcile_telephony.py unscheduled: F-H18
- Live prompt-injection: own unnumbered ticket (not F-C7 and not pentest)

§11 Gate mapping (findings already in the catalog; do not duplicate)

Gate	Finding IDs already in this list	Unnumbered remainder	Wave vs this deadline
1 Stop the bleeding	F-C1, F-C2, F-C3, F-M18, F-M19	—	Wave 2 (not this deliverable)
2 Restore the ability to know	F-H1, F-H2, F-H3, F-M20	—	F-H2 is Wave 1; the rest Wave 2
3 Close legal exposure	F-C4	Legal opinion; sub-processor DPAs; (erasure is F-C4/F-M13)	parked / Wave 2
4 Credential and tool holes	F-C6, F-C7, F-C5, F-H15, F-H8, F-H13, F-H14	Live prompt-injection test	Wave 2
5 Make it operable	F-H11, F-H18, F-H5, F-H6, F-M25	Kill switch / rehearsed rollback	Wave 2
6 Commercial claims	F-H10, F-L3	Capacity sheet; legal/trust pack; billing; status page	parked